M7

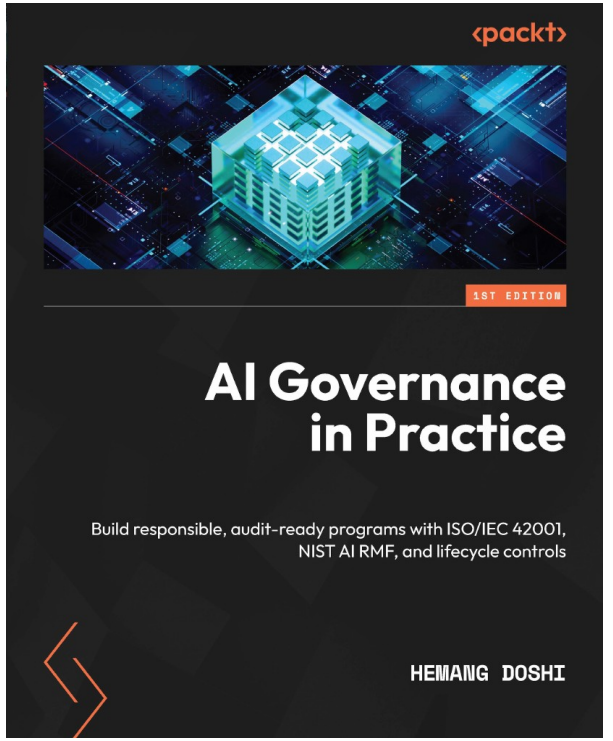
The Rules Landscape

Module 7 — EU AI Act, NIST AI RMF and OECD principles

307307 — BI Methods for Generative AI

AI Governance · University of Petra

Lecturer: _____ Date: _____



AI Governance in Practice — Hemang Doshi (Packt, 2026)

Which Rules Apply to Us?

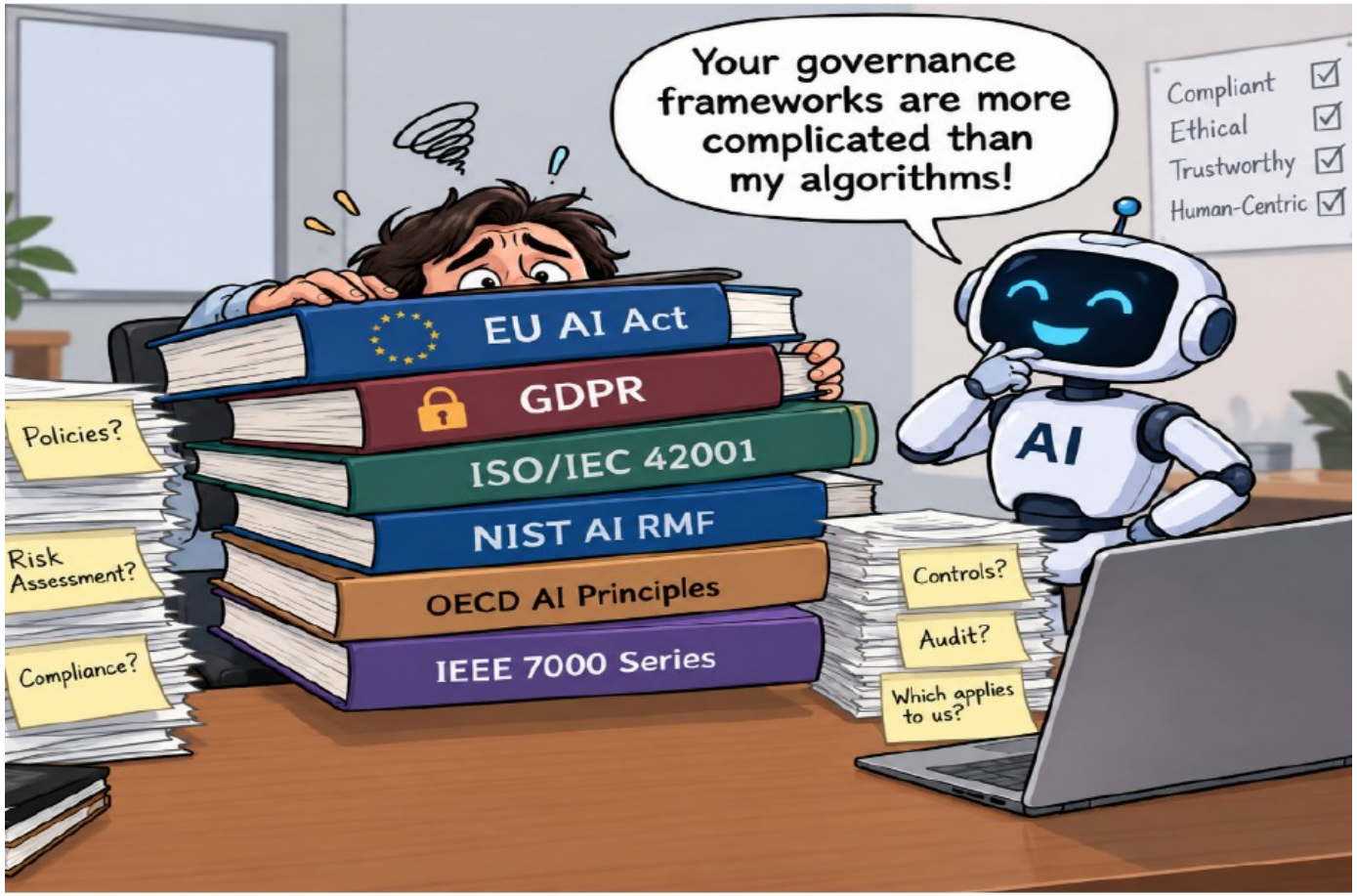


Figure 4.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Questions the company asks

- Which of these apply to us?
- Are they laws, or only advice?
- Do we need six separate programs?

Today's answer in one line: learn what each one is, then look for what they have in common.

What You Will Be Able to Do

1. **Tell apart** a regulation, a standard and a framework, and say which are legally binding.
2. **Classify** an AI system under the EU AI Act’s four risk levels and name the main duties of providers and deployers.
3. **Describe** the four functions of the NIST AI RMF and how a gap analysis works.
4. **Explain** the five OECD AI principles and why governance programs share common themes.

Regulation, Standard, Framework

1 Regulation

Legally binding

Issued by governments or regulators. You must comply, and there are penalties.

Example: EU AI Act, GDPR

2 Standard

Voluntary, unless required

Documented requirements for doing something consistently. You can be certified against it.

Example: ISO/IEC 42001

3 Framework

Voluntary, unless required

Structured guidance and good practice for one area, such as AI risk.

Example: NIST AI RMF

A standard or framework can become mandatory when a law, a contract or a certification commitment requires it. Almost every country is writing its own AI rules, and they build on the Responsible AI principles from Module 6.

The Landscape at a Glance

Name	Type	Issued by	Main focus
EU AI Act	Regulation	European Union	Risk-based AI law for providers and deployers
GDPR	Regulation	European Union	Privacy and data protection, including AI
US Executive Order on AI (2023)	Directive	US government	National AI safety direction to agencies
ISO/IEC 42001	Standard	ISO and IEC	A management system for AI governance
NIST AI RMF	Framework	NIST (USA)	Risk-based management of AI risks
OECD AI Principles	Framework	OECD	High-level principles for trustworthy AI
IEEE 7000 series	Framework	IEEE	Ethical design of AI and autonomous systems
WEF AI Governance Playbooks	Framework	World Economic Forum	Board-level and industry good practice

Based on Table 4.1 of the book.

Update: the 2023 US order was withdrawn in January 2025. US practice now relies on agency guidance and voluntary frameworks such as NIST.

EU AI Act: Scope and Roles

Who must comply?

Anyone whose AI system is placed on the EU market, is used in the EU, or produces outputs that affect people in the EU, wherever the organization is based.

What counts as an AI system?

A machine-based system with some autonomy that infers from data how to produce predictions, recommendations or decisions. Fixed-rule software without learning or inference is generally not covered.

1 Provider

Develops an AI system, or puts it on the market under its own name

2 Deployer

Uses an AI system in its own operations

3 Importer

Brings a non-EU provider's system onto the EU market

4 Distributor

Makes a system available on the EU market without changing it

Four Risk Levels

Prohibited Unacceptable risk	**Banned**	Social scoring · manipulative AI · real-time biometric surveillance in public (limited exceptions) · emotion recognition at work or school
High High risk	**Allowed only with strict requirements**	Recruitment · credit scoring and loans · medical devices · exam and student assessment · critical infrastructure
Limited Transparency risk	**Tell people it is AI**	Chatbots · AI-generated images, audio and video
Minimal Little or no risk	**No special legal duties**	Spam filters · video games · movie and music recommendations

Based on Table 8.1 of the book. The higher the risk, the stronger the rules.

Where Does Each System Fall?

AI system	Likely level
Recruitment and résumé screening	**High**
Credit scoring and loan approval	**High**
Exam proctoring and student assessment	**High**
Medical diagnosis support	**High**
Real-time biometric ID in public spaces	**Prohibited**
Emotion recognition in workplaces or schools	**Prohibited**
Customer service chatbot	**Limited**
AI content tools (text, image, audio, video)	**Limited**
Movie, music or product recommendations	**Minimal**
Spam filter	**Minimal**

Based on Table 8.2 of the book.

Same technology, different use

The category depends on the purpose and the context, not only on the technology.

Facial recognition
to unlock an office door: limited rules.

Used by police for real-time identification in public spaces: prohibited.

Classify It Step by Step

1 Define the purpose

What is the system for, and how are its outputs used in decisions?

2 Prohibited?

Social scoring, manipulation, banned biometrics. If yes: it cannot be used.

3 High-risk area?

Recruitment, credit, health, education, biometrics, essential services. If yes: strict rules.

4 Transparency duty?

Chatbot or AI-generated content? If yes: limited risk. Otherwise: minimal risk.

Then: write down why you chose that level, ask Legal to confirm, and check again whenever a feature or the purpose changes. A bank chatbot that starts to judge creditworthiness becomes a high-risk system.

High-Risk Systems: What Providers Must Do

1 Risk management (Art. 9)

Find and reduce risks across the whole lifecycle

2 Data governance (Art. 10)

Relevant, representative data; detect and reduce bias

3 Documentation (Art. 11)

A technical file showing design, operation and compliance

4 Record-keeping (Art. 12)

Automatic logs for traceability and audits

5 Information (Art. 13)

Clear instructions on abilities, limits and reading outputs

6 Human oversight (Art. 14)

People can monitor the system and step in

7 Accuracy and security (Art. 15)

Accurate, robust against errors and misuse, protected from attack

8 Conformity and monitoring

Assess before launch, CE mark, monitor afterwards, report serious incidents

Deployers must use the system as instructed, keep human oversight, monitor it and act on problems.

Penalties and Enforcement

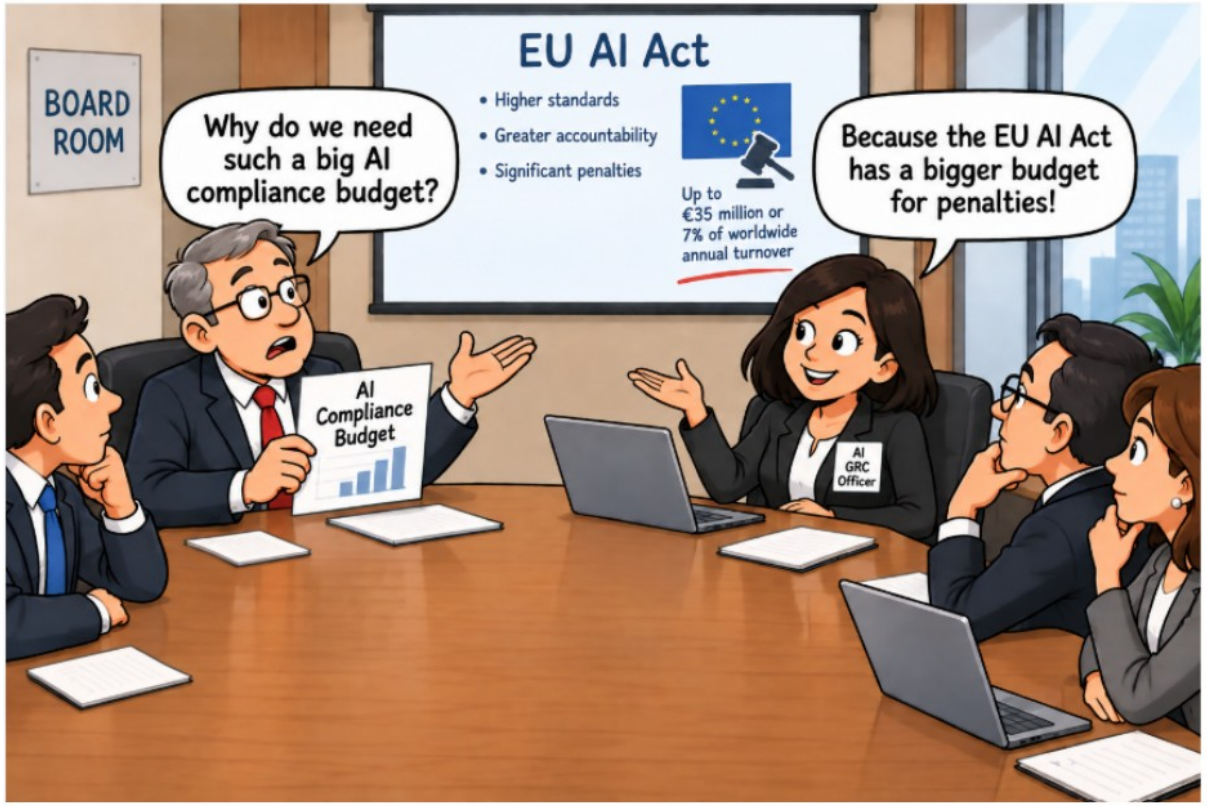


Image 8.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Violation	Maximum fine
Prohibited AI practices	**€35 million or 7% of worldwide turnover**
High-risk obligations not met	**€15 million or 3% of worldwide turnover**
Misleading information to authorities	**€7.5 million or 1.5% of turnover**

Whichever is higher. Based on Table 8.3 of the book.

National authorities can investigate, audit, order fixes, and withdraw systems from the market. People can also complain to them.

NIST AI RMF: Four Functions

1 Govern

6 categories · 19 subcategories

Policies, roles, accountability, culture, third parties

2 Map

5 categories · 18 subcategories

Understand the context, purpose, stakeholders and risks

3 Measure

4 categories · 22 subcategories

Test, measure and monitor risks and trustworthiness

4 Manage

4 categories · 13 subcategories

Prioritize and treat risks, respond, improve

Voluntary, flexible and technology-neutral. Structure: Functions → Categories → Subcategories (19 and 72 in total). Use only the subcategories that fit your organization.

Seven traits of trustworthy AI: valid and reliable · safe · secure and resilient · accountable and transparent · explainable and interpretable · privacy-enhanced · fair, with harmful bias managed.

Putting the NIST AI RMF to Work

1 Profiles

Describe where you are now (current) and where you want to be (target). The difference is your gap.

2 Playbook

Practical suggestions for each subcategory, grouped by the four functions.

3 Crosswalks

Show how the AI RMF lines up with other frameworks, such as ISO/IEC 27001, to avoid duplicate work.

Subcategory	Current profile	Target profile
GOVERN 1.1	AI laws are identified, but not documented or reviewed	Documented, given to owners, reviewed on a schedule
GOVERN 1.3	Systems assessed one by one, no consistent process	Linked to enterprise risk management and the risk register

Illustrative, based on Table 6.2 of the book.

Not a tick-box list. Check which subcategories apply, review what you do now, find the gaps, assign owners, keep evidence, and review again when systems or risks change.

OECD AI Principles

First intergovernmental AI standard (2019), updated in May 2024 for generative AI, safety, information integrity, privacy, copyright and sustainability. Not legally binding, but it shaped the EU AI Act and ISO/IEC 42001.

1

Inclusive growth, sustainable development, well-being

AI should benefit people and the planet, including its energy use.

2

Human rights, rule of law and fairness

Respect rights, democratic values and privacy; avoid unfair treatment.

3

Transparency and explainability

People know when AI is used and can understand its outcomes.

4

Robustness, security and safety

Reliable, secure and safe through the whole lifecycle.

5

Accountability

Clear roles for who answers for how the system works.

One Program, Many Rules

OECD principle	ISO/IEC 42001 (Module 8)	NIST AI RMF
Inclusive growth and well-being	AI policy, objectives, risk assessment, continual improvement	Govern and Map: impacts, benefits and costs
Human rights and fairness	Data governance, human oversight, bias controls	Map, Measure (bias), Manage (risk treatment)
Transparency and explainability	Documentation, communication, disclosure	Map, Measure (explainability), Manage (communication)
Robustness, security and safety	Lifecycle controls, monitoring, incident management	Measure and Manage
Accountability	Leadership, roles, governance structures, audits	Central to Govern

Based on Table 7.1 of the book.

Accountability, transparency, explainability, security, safety and human oversight appear in all six approaches the book compares (Table 4.2). Build shared controls once.

Key Takeaways

1. Regulations are binding, standards and frameworks are voluntary unless a law or contract requires them.
2. The EU AI Act is risk-based: prohibited, high, limited or minimal. Purpose and context decide the level.
3. Your role (provider, deployer, importer, distributor) decides your duties. High-risk systems face strict rules and large fines.
4. The NIST AI RMF organizes AI risk work into Govern, Map, Measure and Manage. Profiles show the gap.
5. The OECD principles give shared values. Look for common themes and build shared controls.

Discussion and Activity

Discuss

1. A student uses an AI tool to write an application essay. Which EU risk level would an AI writing tool fall under, and why?
2. Why might a company follow the EU AI Act even if it is not based in the EU?
3. Which NIST function would you start with in a small organization?

Activity

Which rules apply to six campus AI tools? (a fictional case)

A. Regulation, standard or framework?

B. Classify the six tools

C. Provider or deployer?

D. NIST: one action per function

E. OECD principles in practice

Groups of 3–4. Handout: Module7_Rules_Landscape_activity.docx